

SECURE WEB APPLICATIONS

Case Study

Interim Report (10%)

Group 1

Darren Ong Yan En 2004217B (L)
Justin Chong Tse Kang 2002575E
Lim Yi He Sean 2001906C
Ng Si Yuan, Ryan 2005071B
Zeph Teo Yi Shyan 2003261A

Content Page

Contents

1. Introduction	3
2. Roles & Responsibilities	6
3. Proposed Solution.....	7
4. Database Diagram	8
5. User Privilege.....	11
6. Project Plan.....	12
7. Functional Requirements	17
7.1 Use Cases	17
7.1.1 Login and Signup.....	17
7.1.2 Use Case Inventory.....	19
7.1.2 Use Case Product Management.....	20
7.1.3 Use Case Attendance.....	22
7.1.4 Use Case Tasks System	23
7.1.5 Use Case Scheduling System	25
7.1.6 Use Case E-commerce.....	26
7.2 Abuse Use Cases	27
7.2.1 Brute Forcing password at the Login Page Abuse Case.....	27
7.2.2 SQL Injection Abuse Case.....	28
7.2.3 Cross Site Scripting Abuse Case.....	29
7.2.4 Session Vulnerability Abuse Case.....	30
7.2.5 Denial of Service Abuse Case	31
7.2.6 Directory Traversing Abuse Case	32
7.2.7 Cross Site Request Forgery(CSRF)	33
8. Non-Functional Requirements.....	34
8.1 Application Security	34
8.2 Costs	35
8.3 Maintainability.....	36
8.4 Scalability.....	37
8.5 Logging	37
8.6 Backup	38

8.7 Multi-lingual support	38
8.8 Load Balancing	39
9. Test Plan.....	39
10. Appendix.....	44
Appendix A.....	44
Appendix B.....	45
Appendix C.....	46
Appendix D.....	47
Appendix E.....	48
Appendix F	49
Appendix G	50
Appendix H.....	51
Appendix I	52
11. References.....	53

1. Introduction

Project Purpose

Our team was tasked to propose, plan, design, develop and test a software application focused on solving a problem pertaining to TP's low-volume, high-variation Advanced Manufacturing Centre (AMC).

Our solution aims to **streamline the ordering, customization, and marketing of AMCs products as well as the management of HR and employees at the AMC** through a multi-faceted e-commerce web application. This application would have the following features:

- Register & Login
- Scheduling System
- E-commerce
- Inventory Ordering and Storage System
- Tasks management
- HR Management
- Systems management (for admin)

Proposed Security Measures

Some of the security measures put in place to ensure the **confidentiality** of user's information, **integrity** of transactions and interactions, **availability** of resources are:

Confidentiality

- Using salting and hashing to encrypt password
- Enforcing password policies
- Authentication
- Encrypt sensitive data
- Include Auditing & Logging
- Intrusion Prevention System & Detection

Integrity

- Authentication
- Session management
- Secure login token
- Quality Control Measures
- Least required privileges
- Include Auditing & Logging

Availability

- Redundancy
- Error handling
- Host database and website in a secure place
- Minimize downtime through load balancing

End-To-End Security and Design Principles

End-To-End Security

To ensure **end-to-end security**, data should be secured in such a way that only a sender and receiver have access to it. Our solution makes use of HTTPS using an SSL encryption certificate. In doing so, all HTTP traffic will no longer be transmitted in plaintext, instead, it would be encrypted.

Design Principles

Secure design principles are imperative for the effective functioning of any solution and application. The following are a few design principles that could be used to ensure a secure design.

Protecting Sensitive Data

All sensitive data is required both legally and sustainably to be protected. For security reasons, this data must be encrypted **in motion and at rest**. Good practice is to encrypt and protect not as sensitive data as well. User passwords are to be hashed

and salted. When utilizing third-party clouds, it is important that the developing company is accountable for the security of that data.

Assume Compromise and Do not Trust/ Least Required Access and Permissions

Under this design principle, the goal is to **minimize the attack surface**, and have **backup authentications**. This way, if the attacker bypasses one level of security, there will be more measures to impede the execution of devastating blows. It is important that all users are given the least required permissions.

Always verify and authenticate users before escalating privilege or before executing high-impact commands. Closing every unnecessary port on a server, verifying access on every single page of the application and utilizing a third party tester to point out any vulnerabilities from an objective, unbiased point of view.

Backup and Rollback

This design principle focuses on the Availability angle of the CIA triad. In this principle, data backups must be secure and readily available for roll back in case of any scenario that requires it. Backup will not be valuable unless you can roll back to them efficiently. With efficient rollback of backup, the company can get back on track fast without wasting time to recover and fix the issue.

Server-Side Security Validation

Server-Side Security Validation validates the inputs sent by clients to make sure that it is safe for the web application. The web application would require penetration testing to ensure that the validation works and if the data validation fails, the server will send a response back to the client with corrections that the user needs to make. This helps to prevent attackers from exploiting the web application.

Framework Security Features

Framework Security Features are frameworks created by professionals to help minimize risks and attacks on an application. It is important as it helps developers make their applications more secure which reduces attackers.

Applying these design principles to any application, developers can reduce the impact of cyber-attacks and achieve a more secure, robust, and data-friendly application.

2. Roles & Responsibilities

Name	Roles and Responsibilities
Darren (Team Leader)	- Creator of database - Developer and Tester booking time slots - Developer and Tester stores and products - Developer and Tester employee tasks - Co-Developer and Tester past purchases - CRUD employee account - CRUD employee attendance system
Zeph	- Co-Developer and Tester of Email OTP Verification - Developer and Tester of Google 2 Factor Authentication - Co-Developer and Tester of Captcha - Developer and Tester checkout and card payment - Co-Developer and Tester booking time slots - CRUD users carts
Sean	- Developer and Tester of Email OTP Verification - Co-Developer and Tester of Google 2 Factor Authentication - Developer and Tester of Captcha - Co-Developer and Tester checkout and card payment - Co-Developer and Tester employee attendance system - CRUD store products
Ryan	- Co-Developer and Tester session timeout token - Developer and Tester cart - Co-Developer and Tester login and signup - Co- Developer and Tester employee tasks - Developer and Tester employee attendance system - CRUD employee tasks
Justin	- Developer and Tester session timeout token - Co-Developer and Tester cart

	- Developer and Tester login and signup - Developer and Tester past purchases - Co-Developer and Tester stores and products - CRUD users past purchases
--	--

3. Proposed Solution

Problem

TP AMC is well-organized in its manufacturing process, from assembly up till packaging, but it still lacks a boon in its sales department. **TP students** are still unaware of how they can **utilize** this station or **purchase** its produce. TPAMC, as we know it, currently also does not have any means to **monitor HR**.

Solution

This project aims to provide a working solution to improve TPAMC's **Services, Sales,** and **HR** sectors through a secure web application.

To improve TPAMC's Sales and Manufacturing component, the website will include a centralised medium for sales of its manufactured products(torchlight, limit switch). To further enhance current HR management, a tasks delegation system will be implemented alongside attendance and employee registration. Our solution contains a total of 8 different actors. Each one with varying levels of access and privileges. There are public users, authenticated users, employees, managers, and server admin roles.

Managers can perform inventory, attendance, product, and tasks management. With the implementation of this application solution, the AMC would operate on heightened efficiency, efficacy, and sustainability.

4. Database Diagram

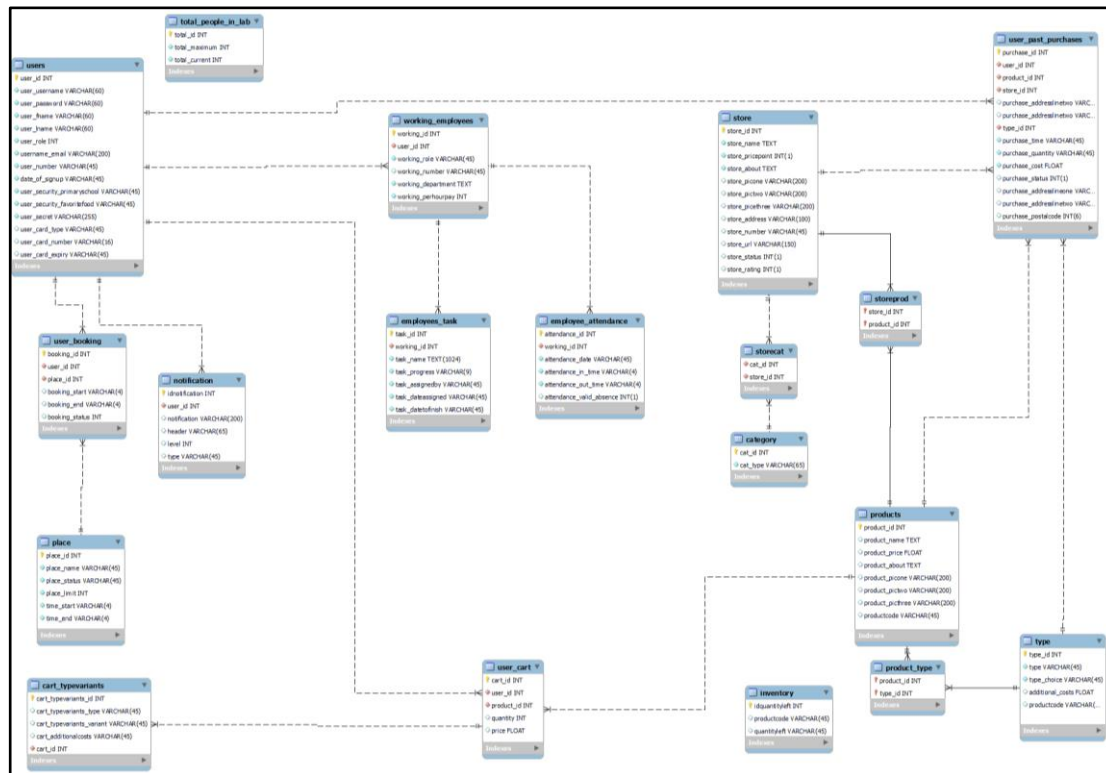


Diagram 1: EER Diagram (in Appendix A)

Table	Purpose
users	- Store users personal information like username, password, firstname, lastname and email. - Stores security signup information regarding user's primary school and favourite food to ensure more secure logging in and to help user's when they forget their password - Stores special secret code for the google authenticator QR Code - Stores users credit card information to help users with more fluent payment when using webpage services. Only the CVV won't be stored. Additionally, it will be encrypted using a secret. - Passwords will be hashed two times using a salt and pepper(Pepper will be generated based on the user's

	username)
user_booking	- Stores the user id which is the foreign key to users table - Store booking and place id for users and admin to refer to when users book the place - Stores the start and end time of each booking for users to refer to - Stores the status of the booking so that users can see if the booking is pending, confirmed or declined.
total_people_in_lab	- Stores the maximum number of people allowed inside the lab - Stores the current number of people inside the lab
user_past_purchases	- Stores product, user, store, type id which is the foreign key to products, user, store, type tables respectively - Stores user purchase addresses - Stores user purchase time, quantity, cost, status, postal code - Identifies which user purchased the item
user_cart	- Stores user and product id as a foreign key to user and product table respectively - Stores the cart id so that it can be referred to by the admin or vendors to see what is inside the cart - Stores user id so that user can be identified - Stores the product id and quantity bought - Stores the total price of user cart
cart_typevariants	- Stores cart id as a foreign key to user cart table - Responsible for knowing which types and which variants the user has chose
place	- Stores place id as foreign key to the user_booking table - Store names of different places in the TP AMC - Stores status of place etc(available,unavailable) - Stores maximum occupancy limit - Stores start and end time available for booking
store	- Stores names of different stores - Stores price points of different stores

	- Stores about store(description) - Stores thumbnails of stores - Stores address of stores,contact number,url and status, rating
storecat	- Stores category id and store id as foreign key to table category and store respectively
category	- Stores the different store category types
storeprod	- Stores store id and product id to connect the 2 tables together
products	- Store product id so that product can be identified easily - Store basic information of product like price, name , about (info), picture1, picture2, picture3 - Code column stores product name, type, and variants into one line of string. This is hashed and put inside. This is done for products that do not have types and variants(E.g. Size and XL).
product_type	- Stores product id and type id as a foreign key to products and type table respectively - Code column stores product name, type, and variants into one line of string. This is hashed and put inside. This is done for products that have types and variants.
type	- Stores type of product as well as choice and additional costs
employees_task	- Store task id so that employees and admin can identify task easily - Store working id to show the status of employee if they are currently working or on break - Also stores working id as foreign key to working_employee table and employee_attendance table - Store the name of task and the current progression employees have with the task
working_employees	- Store user_id to map an existing user. Employees will have to create their own account. EM,OM, or SM will

	then assign these existing users to an employee - Store pay rate of employees - Store the roles of the employees like engineer, manager, vendor
employees_attendance	- Store attendance id that is assigned to a date - Store date of attendance, time employees sign in, time employee signout - Stores information if employee is absent
inventory	- Code column stores product name, type(if any), and variants into one line of string. This is hashed and put inside. - This ensures that inventory is matched for each product and its corresponding type - Quantity column to check the total amount left
notification	- Consists of user_id to identify which user is responsible for which notification - Notification information to tell the user what it is about - Header for the notification for the user - Level for the urgency of notification and type for the category

5. User Privilege

No	Users	Legend	Permissions & Privileges
1	Public User	PU	- Able to view the public website and ecommerce without purchasing - Cannot access booking system
2	Authenticated User	AU	- Able to view the website and buy products from stores but cannot access booking system - Able to perform CRUD on their own account - Able to view, add, modify and remove products from

			their cart - Able to view past purchases
3	Employee	Employee	- Able to access the employee booking only website - Able to view and update status of the tasks
4	Employee Manager	HR	- Able to edit and view the public and access the employee booking only website - Able to view employee admin page - Able to perform CRUD on tasks to employees - Able to perform CRUD on employee account
5	Store Manager	SM	- Able to edit and view the public and access the employee booking only website - Able to view storeadmin page - Able to order materials from manufacturer - Able to view materials inventory - Able to perform CRUD on shop & products
6	Booking Manager	BM	- Able to edit and view the public and access the employee booking only website - Able to view booking admin page - Able to perform CRUD on time slots
7	Overall Manager	OM (BM,SM,H R)	- Able to do 3,4,5 roles - Able to view all admin page - Able to perform CRUD on employee accounts.
8	Server Admin	Admin	- Have access to everything on the website - Able to perform CRUD on public users and employee accounts. - Able to view all admin page - Able to change roles but not to Admin role

6. Project Plan

For our project plan, we have created a Gantt chart to give us a visual display of the whole project. This further assist us in the planning and scheduling of tasks to be done in an organized and neat manner. In the Gantt chart, we have included the various phases of our plan, timelines, and deadlines of all tasks. The PDF version of our Gantt chart is attached in the appendix below(Appendix B).

Work Breakdown	Duration	Start	Finish	Remarks
Phase 1: Design & Planning				
Review & analyse customer requirements	2 days	27/10/2021	28/10/2021	All Members
Develop Class Design	2 days	30/10/2021	31/10/2021	All Members
Develop Use Case Diagram	1 day	1/11/2021	1/11/2021	All Members
Design DB Schema / Database	2 days	3/11/2021	4/11/2021	Darren
Design Test Plan	2 days	6/11/2021	7/11/2021	All Members
Design Threat Model	1 day	10/11/2021	10/11/2021	Sean & Ryan
Complete Design Document	1 day	12/11/2021	12/11/2021	All Members
Phase 2: Development				
Develop SSL Certificate	5 days	15/11/2021	19/11/2021	Darren
Develop Routing In Website	5 days	15/11/2021	19/11/2021	Darren

Test Features #1	1 day	20/11/2021	20/11/2021	Ryan
Develop User Registration Feature	1 day	15/11/2021	15/11/2021	Sean & Zeph
Develop User Login Feature	1 day	15/11/2021	15/11/2021	Sean & Zeph
Test Features #2	1 day	16/11/2021	16/11/2021	Darren
Develop Session Manager Feature	1 day	16/11/2021	16/11/2021	Justin & Ryan
Develop Session Expiry Feature	1 day	16/11/2021	16/11/2021	Justin
Develop Remember Me Feature	1 day	17/11/2021	17/11/2021	Ryan
Test Features #3	1 day	18/11/2021	18/11/2021	Darren & Zeph
Multi-Factor Authentication (Google 2 Factor Authentication)	7 days	24/11/2021	1/12/2021	Sean & Zeph
Multi-Factor Authentication (Email OTP)	7 days	24/11/2021	1/12/2021	Sean & Zeph
Test Features #4	2 days	2/12/2021	3/12/2021	Justin & Ryan
Develop E-Commerce Page	3 days	27/11/2021	29/11/2021	Darren

Develop Task Feature	4 days	27/11/2021	1/12/2021	Zeph
Test Features #5	1 day	3/12/2021	3/12/2021	Sean
Develop Admin System Management Pages	2 days	2/12/2021	3/12/2021	Sean & Ryan
Develop Attendance Feature	1 day	4/12/2021	4/12/2021	Justin
Develop HR Management Panel	2 day	6/12/2021	7/12/2021	Darren
Test Features #6	1 day	9/12/2021	9/12/2021	Ryan
Develop Time Slot Booking Feature	5 days	16/12/2021	20/12/2021	All Members
Develop Inventory Ordering & Storage System	2 days	21/12/2021	22/12/2021	Darren & Ryan
Develop Display Current Inventory	1 day	21/12/2021	21/12/2021	Sean,Justin,Zeph

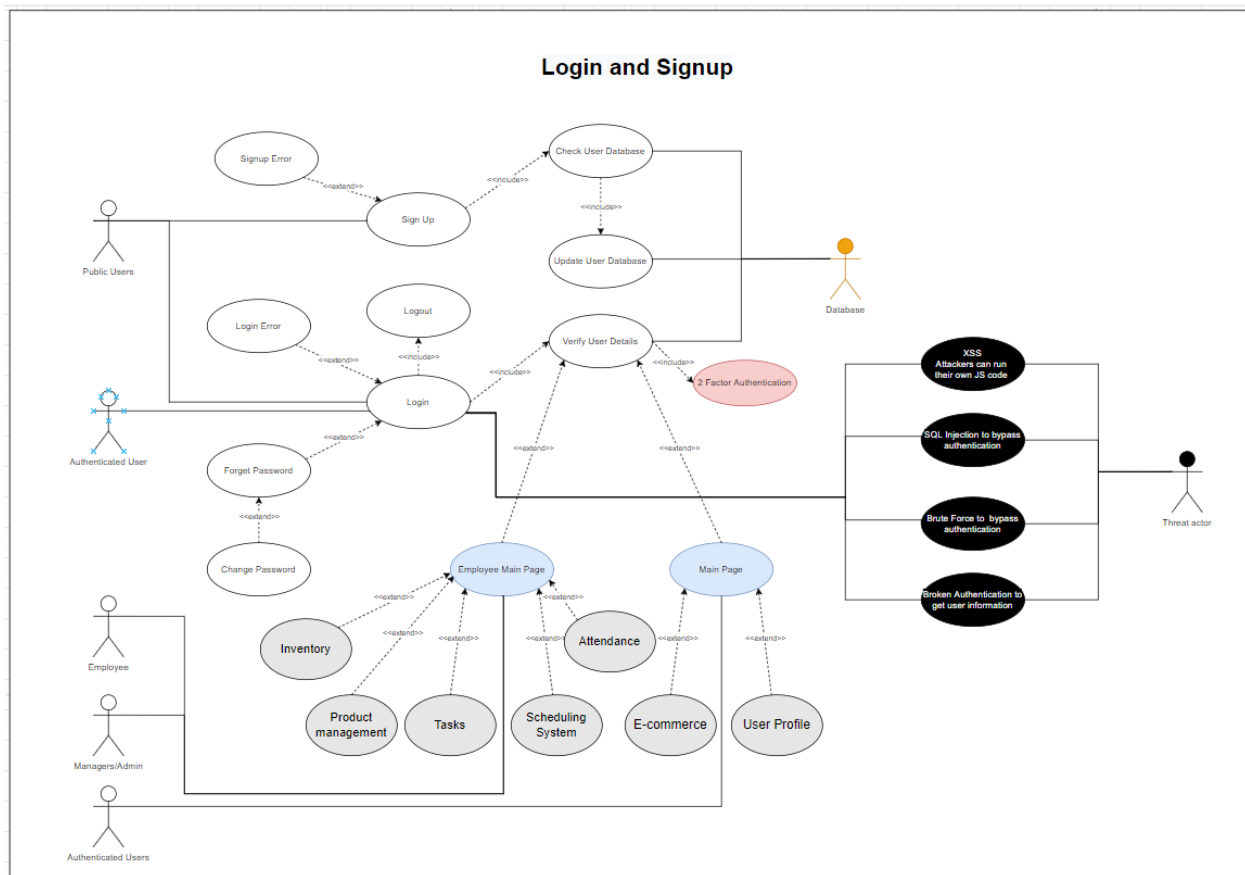
Features Testing	1 day	26/12/2021	26/12/2021	Requires all developments to be finished first. (Darren)
Website Designing(Done Simultaneously with Phase 3,4,5)	23 days	27/12/2021	18/1/2022	All Members
Phase 3: Enhancement				
Patch Potential Vulnerabilities	1 day	31/12/2021	31/12/2021	Zeph & Darren
Improve Present Features	1 day	4/1/2022	4/1/2021	Justin & Ryan & Sean
Phase 4: Testing				
Functional Testing	1 day	6/1/2022	6/1/2022	Ryan
Non-Functional Testing	1 day	8/1/2022	8/1/2022	Sean
Unit Testing	1 day	10/1/2022	10/1/2022	Darren
System Testing	1 day	12/1/2022	12/1/2022	Justin
Acceptance Testing	1 day	14/1/2022	14/1/2022	Zeph

Security Testing	1 day	16/1/2022	16/1/2022	Darren
Phase 5: Deployment				
Deploy Web Application	1 day	20/1/2022	20/1/2022	All Members

7. Functional Requirements

7.1 Use Cases

7.1.1 Login and Signup

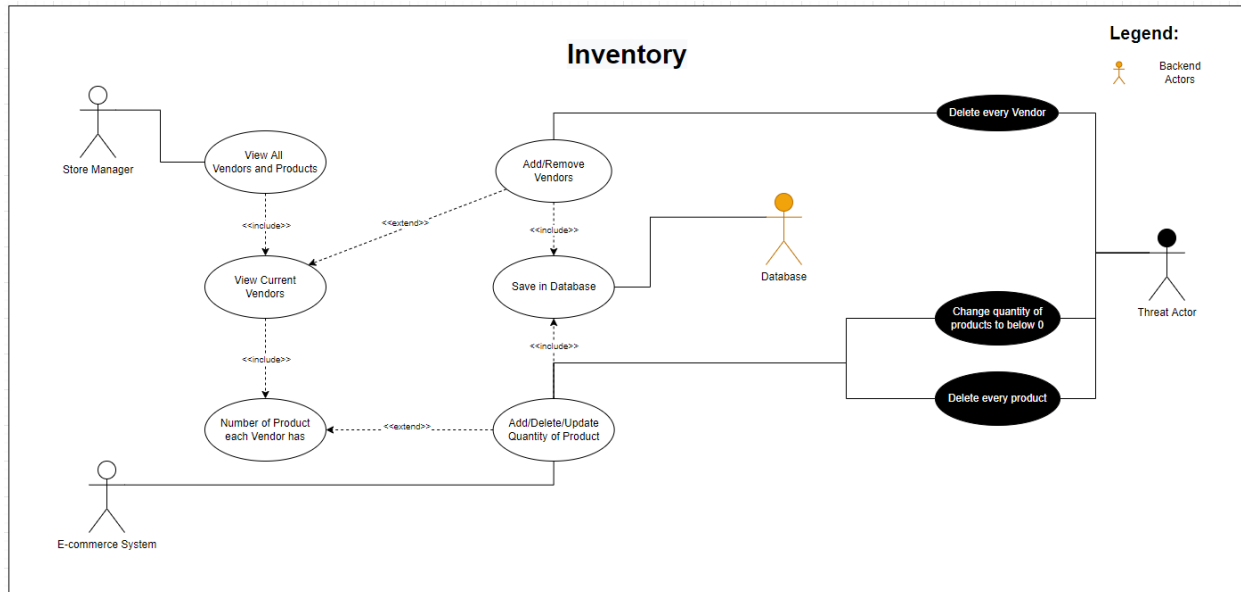


Appendix C: Login and Signup use case

Description	This scenario describes the situation where employees can login into the system to log their attendance. HR Managers will also be able to manage employee's attendance
Actors	- Public users - Authenticated User - Employee - Managers/Admin - Database
Triggers	- Book or Buy products from TPAMC
Pre-conditions	- Users must be logged in to book or buy products
Basic-Flows	The users must first sign up for an account. Then, they will need to login and do 2FA to enter the main page. The 2FA will consist of the Google Authenticator and email verification.
Alternate Flow 1	Users forget the password and need to recover it
Alternate Flow 2	An email inside the database already exists
Alternate Flow 3	Users have existing username/email registered
Alternate Flow 4	Users do not meet our password requirements which cannot consist of special characters such as 1. . 2. ; 3. ' or ' 4. " or " 5. _ 6.) or (7. / 8. [or] 9. { or } 10. < or > Additionally, it must be of length 8-20, with a number and special symbol apart from the above
Post-conditions	The user will be logged in and have a token using JWT which will define which pages are accessible. This is done by the

“role” data.

7.1.2 Use Case Inventory

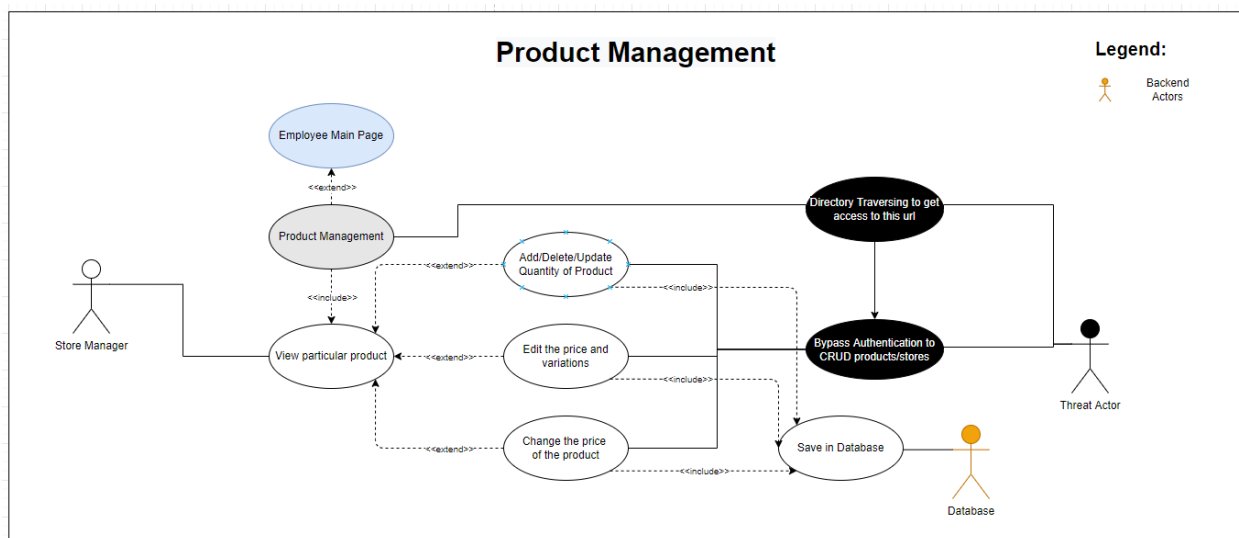


Appendix D: Inventory use case

Description	This scenario describes the situation where the store manager can check the current list of vendors and the current quantity of products they are selling. They are able to change the number of varying products. The inventory feature allows TPAMC to decide the quantity of a certain product. If the stock is low, the Inventory manager is allowed to purchase it from the different vendors on the store.
Actors	- Store Manager - E-Commerce system - Database
Triggers	- Update the list of vendors - Check the inventory of each store - Change the price of the product

	- Add/Delete/Update quantity of product
Pre-conditions	- Only store manager, overall manager, and server admin can check inventory
Basic-Flows	When store managers want to add vendors to the list of vendors, they can view all the vendors on a list first. From there, they can choose to add vendors to the list. Vendors are external parties who would want to sell items to us so that we are able to produce the products. If store managers want to add products, they can choose a specific vendor to view all products they are selling. Then, they can add products that are being sold.
Alternate Flow 1	If store managers want to delete products/vendors, they can do it the same way they add products/vendors.
Alternate Flow 2	If store managers want to change the price of the product, they can go to the specific vendor inventory product page and edit the price of the product
Post-conditions	Quantity for a certain product will be edited

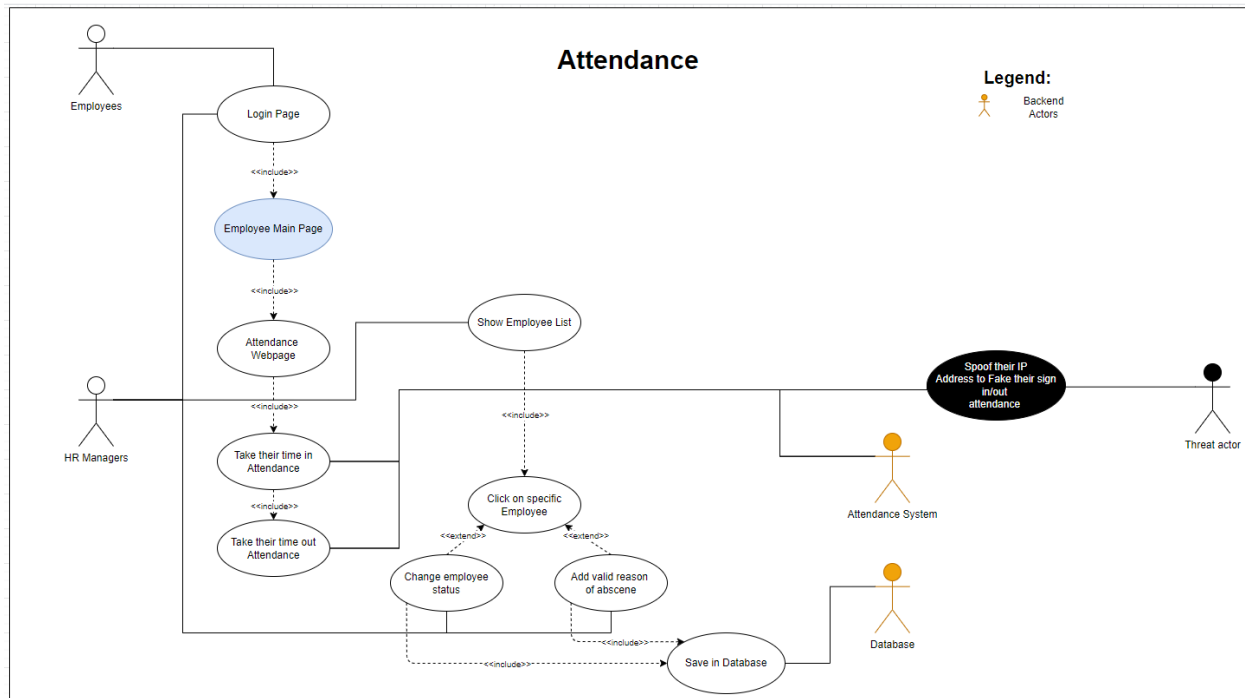
7.1.2 Use Case Product Management



Appendix E: Product Management use case

Description	This scenario describes the situation where store manager can manage the products of the TPAMC storefront.
Actors	- Store Manager - Database
Triggers	- New - New sales items - Fluctuation of cost of sales product
Pre-conditions	- The user must be logged in with store manager's rights or higher.
Basic-Flows	A store manager will be notified of any changes to the cost price of any sales product. They will also be notified of any new products and their respective prices. A store manager would then fill in the details to register a new product on the store front. They would identify the product and update the database of prices.
Alternate Flow 1	If any products turn out of sales, the product will not be shown.
Post-conditions	Inventory systems will be updated.

7.1.3 Use Case Attendance

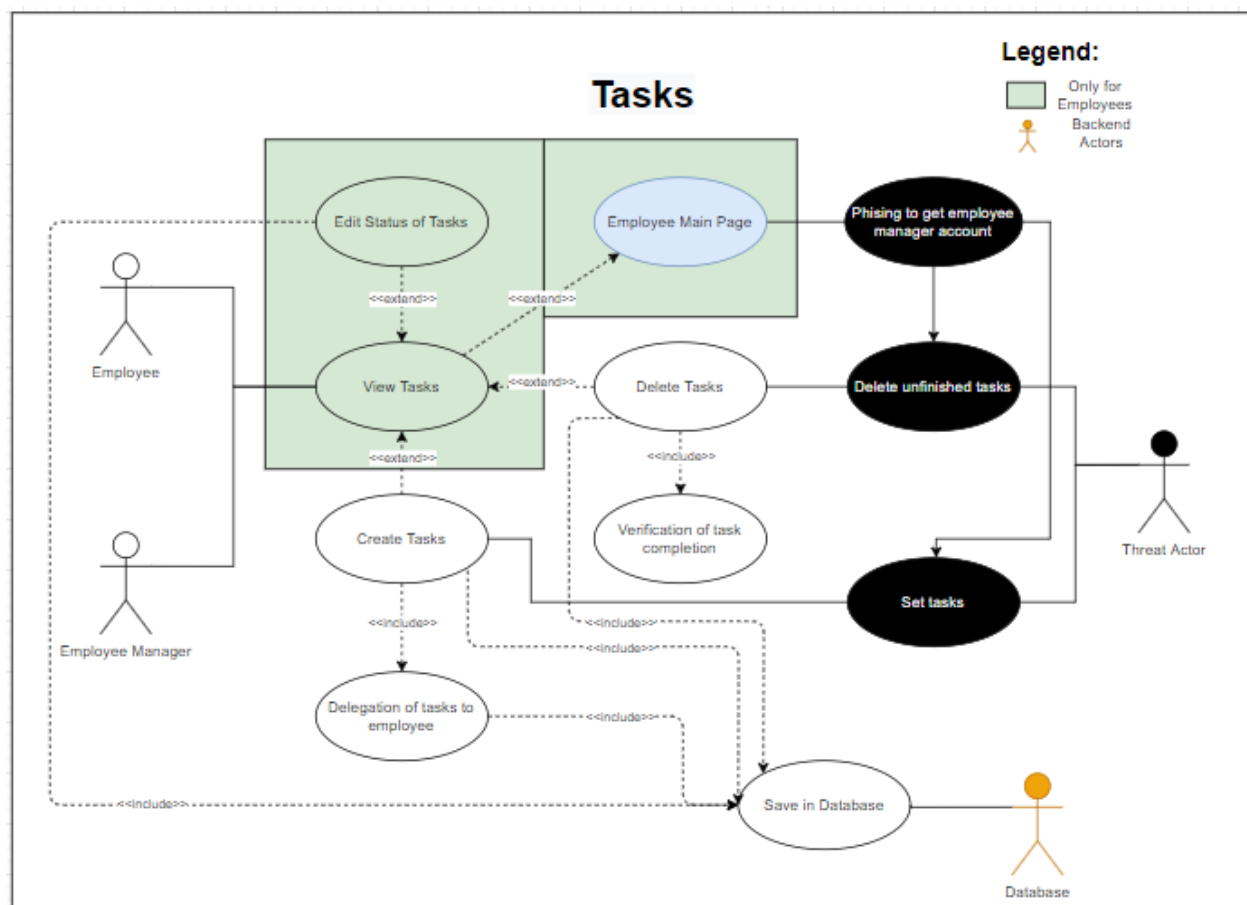


Appendix F: Attendance use case

Description	This scenario describes the situation where employees can login into the system to log their attendance in. HR Managers will also be able to manage employee's attendance. This is under the assumption that employees can only take their attendance in TPAMC. Followingly, data will be sent to the server for managers to keep track.
Actors	- Employees - HR Managers - Database - Attendance Sustum
Triggers	- Login / out attendance for the day
Pre-conditions	- Employees must be logged in the website to log attendance

	- The Manager must be logged in with HR Manager's rights or higher.
Basic-Flows	When employees login into the website, they will be able to access the attendance webpage to take their attendance for the day. HR Managers will be able to show the employee list.
Alternate Flow 1	HR Managers will be able to change employee's attendance status as needed
Alternate Flow 2	HR Managers will be able to add valid reason of absence for employees if needed
Post-conditions	Attendance will be logged to calculate the pay for that particular day

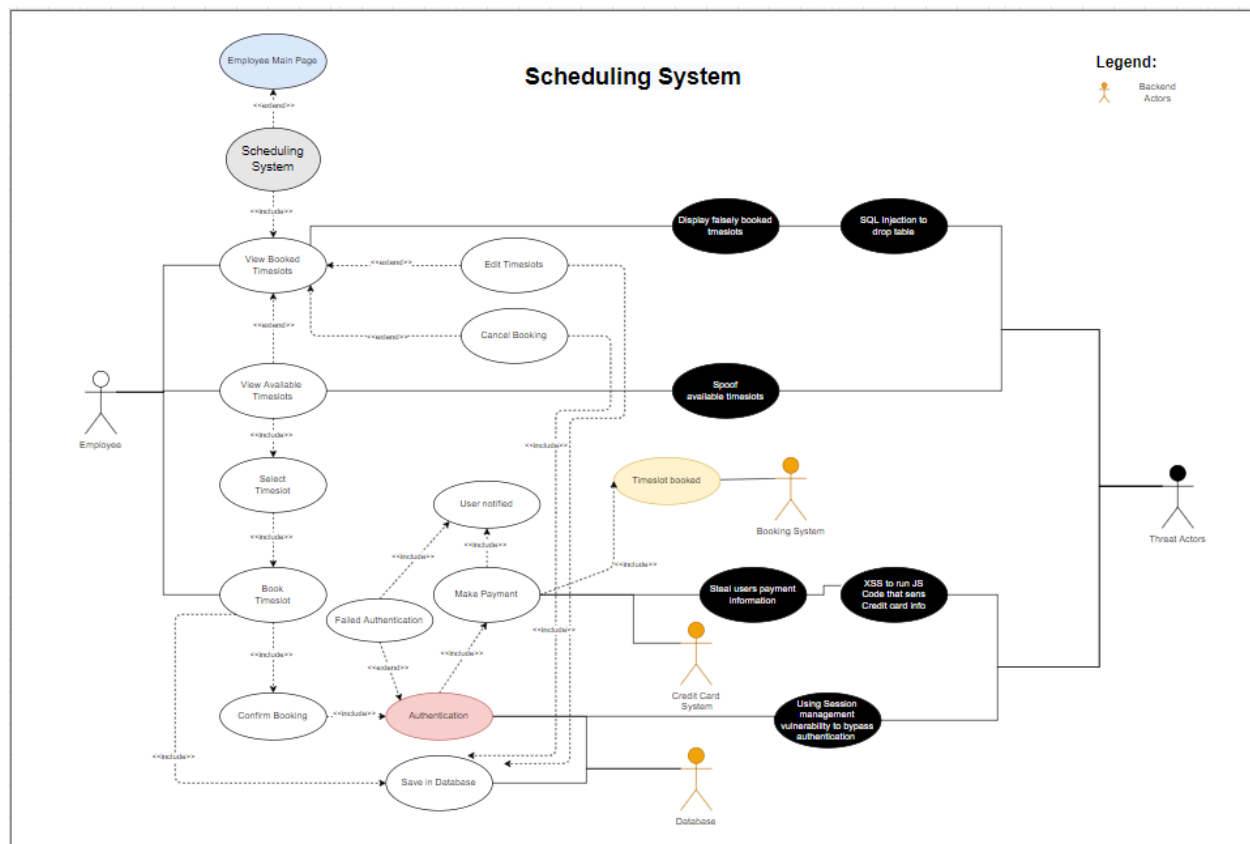
7.1.4 Use Case Tasks System



Appendix G: Tasks use case

Description	This system is created to enable Employee Manager to distribute tasks.
Actors	- Employee - Employee Manager - Database
Triggers	- Issuing of tasks by manager (EM,OM,SA) - Tracking progress by manager(EM,OM,SA)
Pre-conditions	- Employees and Employee Manager must be logged in as Employee and Employee Manager respectively to access the task page. - The Employee manager must know the name of the employee to be assigned the task.
Basic-Flows	Both employee and Employee Managers are able to view tasks if any. The Employee Manager will assign a task to an employee. The employee will then carry out the task, update the status to complete when done, and the manager would verify and clear the task.
Alternate Flow 1	If the employee exceeded the deadline, the progress will be overdue and be alerted to the employee manager.
Post-conditions	Completed tasks will no longer be visible for employees

7.1.5 Use Case Scheduling System

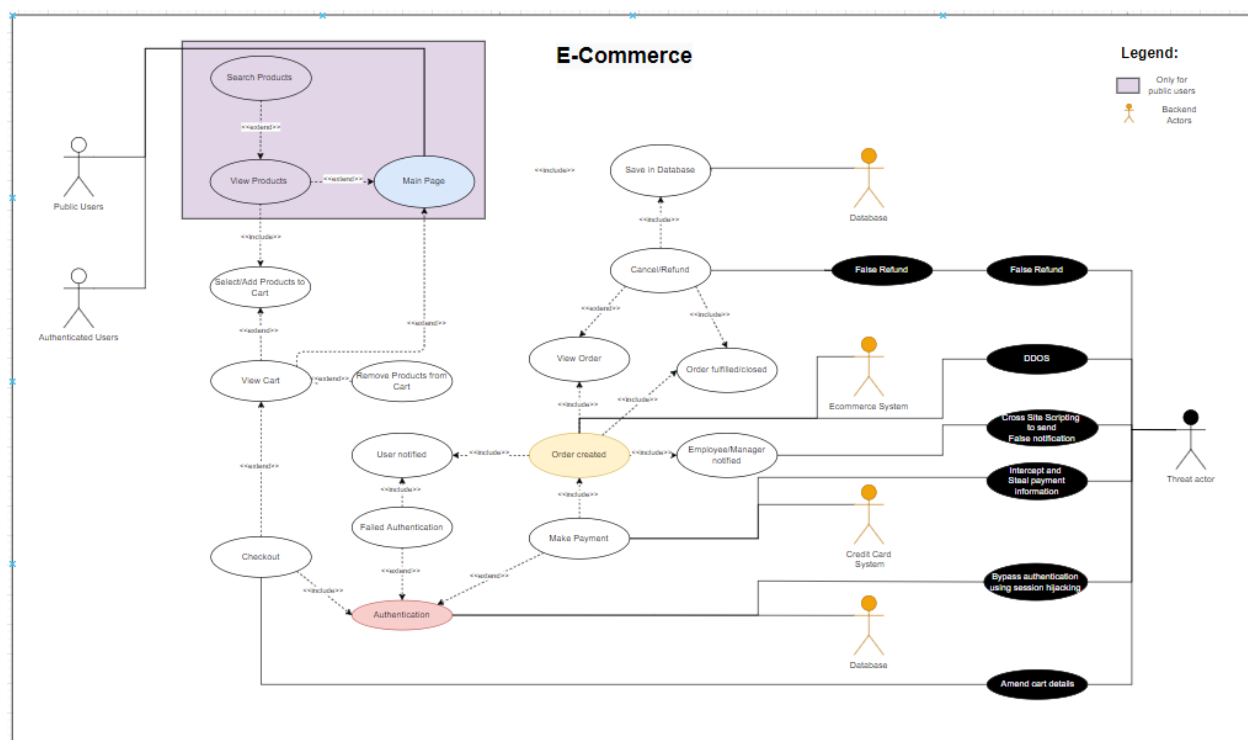


Appendix H: Scheduling use case

Description	This scenario describes the situation where users enter the website to book for a timeslot
Actors	- Employee - Booking system - Credit Card System - Database
Triggers	- Booking of slots in TPAMC
Pre-conditions	- Users must be logged in to buy products and book slots - Employees must logged in as employee to access the admin page
Basic-Flows	Upon login, users can view the time slots that the facility is available for projects and book available time slots.

	Users will be required to re-authenticate before payment is authorized, and their order is created.
Alternate Flow 1	Users can cancel their time slot bookings for a small fee.
Alternate Flow 2	Users can edit their time slot after booking if it is available.
Post-conditions	Booked slots can no longer be booked by someone else.

7.1.6 Use Case E-commerce



Appendix I: E-Commerce use case

Description	This scenario describes the situation where users enter the website to buy products.
Actors	- Public Users - Authenticated Users - Database - Ecommerce System - Credit Card System - Database

Triggers	- Ordering products from AMC
Pre-conditions	- Users must be logged in to buy products - Employees and Store Manager must be logged in as employee and store manager respectively to access the admin page
Basic-Flows	After verification and logging in, users can access the main page and view products sold at the AMC. Next, they can view the products. If they are interested in the product, they can add it to their cart for checkout. Users can then view their shopping cart and checkout. Users will be required to re-authenticate before payment is authorized, and their order is created. The user, employee, and store manager will be notified of a new order to be produced and created.
Alternate Flow 1	Users can remove items from the cart. They can then checkout with a newly updated cart.
Alternate Flow 2	If a user fails authentication, they will be unable to make payment and the order will not be placed.
Post-conditions	Order is created. The public user/customer will be waiting on a notification from the AMC for the collection of the purchased item. Employee and Store manager will be required to manufacture the product and notify the customer upon completion

7.2 Abuse Use Cases

7.2.1 Brute Forcing password at the Login Page Abuse Case

Description	This abuse use case displays what a script kiddie might do to hack our login system. The purpose of this would be for the attacker to compromise or gain control of someone else's account.
--------------------	---

Actors	- Script Kiddie - Online thief - Penetration Tester
Triggers	- For entertainment purposes - Penetration testing - To get higher level access by brute forcing Administrative accounts
Pre-conditions	An input box for user input to login will be required.
Basic-Flows	The threat actor can use tools like Jack the Ripper, THC-Hydra, Hashcrack and Aircrack to run programs that allow them to try and brute force password attacks on our website. If users of the application have basic passwords that can be found in the attackers dictionary, attackers will gain access to users accounts.
Alternate Flow 1	If the attackers are unable to find passwords, then the threat actors would be unable to gain access.
Post-conditions	The attacker may have gained access to someone's account. The login function may have been executed from hundreds to thousands of times and more depending on the strength of the password and the time taken.

7.2.2 SQL Injection Abuse Case

Description	This abuse case describes how an attacker would attempt to view sensitive information or alter data through an area of user input specifically towards weaknesses regarding the SQL scripting language.
Actors	- Threat actor - Employee - Online thief

	- Penetration tester
Triggers	- Penetration testing - Theft of user information - Privilege escalation to cover up tracks - Revenge on another employee or an action to cover up one's mistake(e.g.,).
Pre-conditions	- An input box or an address bar for user to input values
Basic-Flows	Attackers can attempt to do SQL Injection at every possible form or area that requires input available for users to key in their input. If any of the user input boxes or address bars are not secured and protected against SQL Injection, users will be able to gain access to information.
Alternate Flow 1	If the input box or address bar is secured with regex functions and prepared sql statements, and all input is sanitised, the attacker will be unable to retrieve the information.
Post-conditions	An SQL statement would be executed. On success, the attacker may be able to create, retrieve, or update users or delete whole tables.

7.2.3 Cross Site Scripting Abuse Case

Description	Similar to SQL Injection, XSS is able to manipulate inputs(URL, Input boxes) to run malicious scripts. XSS comes in the form of reflected or stored, DOM, and mutation. These malicious code can persistently change database information that can affect other users maliciously.
Actors	- Threat actor - Online thief - Penetration tester
Triggers	- Penetration testing

	- Theft of user information - Privilege escalation to cover up tracks
Pre-conditions	- An input box - Address bar - Unprotected Javascript “.innerHTML” on the page
Basic-Flows	Attackers can attempt Cross Site Scripting on any available user input form or URL that is available. If any is not secured properly, attackers can key in their own javascript code and users will not be able to notice at all. Depending on what the attackers decide to put inside the javascript code, they can get anything they want from user password, information, credit card credentials or even spy on their every action on the webpage.
Alternate Flow 1	If important information like prices are stored visibly and pulled from the code, attackers may be able to edit those values and the server may retrieve and execute the edited values instead of the
Alternate Flow 2	If the input box or address bar is secured with regex functions and prepared sql statements, and all input is sanitised, the attacker will be unable to retrieve the information.
Post-conditions	The web application’s code will be executed. If the malicious code was successful, the attacker may potentially have the entire website completely compromised.

7.2.4 Session Vulnerability Abuse Case

Description	In broken authentication and session management vulnerability, an attacker aims to illegally impersonate an authenticated user to perform an action. Similar to brute forcing, the purpose of this abuse case would be for the attacker to compromise or gain control of someone else’s account.
Actors	- Threat actor - Script kiddie - Online thief

	- Penetration Tester
Triggers	- For entertainment purposes - Penetration testing - To get higher level access
Pre-conditions	- An authenticated user's session is required to be established - The attacker should be able to tap into the communications between the server and the client. - The attacker has an existing authenticated user account.
Basic-Flows	Attackers can try to enter someone else's session through broken authentication. Attackers can use man-in-the-middle tools to steal cookie information to impersonate another user. If the cookie is in cleartext (E.g. "role: admin"), users can also use these information to change their privileges.
Alternate Flow 1	Attackers may listen in on other user's communications with the server and capture any plaintext important information.
Post-conditions	Attackers gain access to their booking slots as well as their credit card information that is saved.

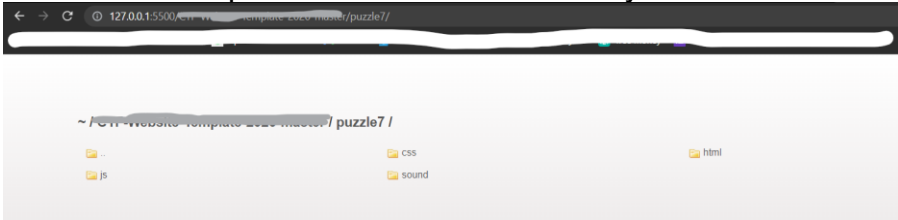
7.2.5 Denial of Service Abuse Case

Description	A threat actor would make use of bots or scripted programs to simulate a large number of users communicating simultaneously with the server, overwhelming it to bring it down.
Actors	- Threat actor - Competitor Companies - Black Hat Terrorists - Script kiddie

Triggers	- Malicious intent - Monopoly in the market - Entertainment
Pre-conditions	- Functions that require a portion of the server's computational power
Basic-Flows	An attacker would script or create a code that would create traffic to flood the server and bring it down.
Alternate Flow 1	An attacker might compromise several machines and execute a distributed denial of service, which is essentially a denial of service but with a multitude of machines.
Alternate Flow 2	If there was load balancing or firewall technologies(IPS) to filter out suspicious traffic, the server will filter out these traffic and not need to process all the requests generated by the attacker.
Post-conditions	A large number of requests will be sent out from the front end. Upon success, entitled users will be deprived of any user attempting to access the website.

7.2.6 Directory Traversing Abuse Case

Description	Directory Traversing abuse cases describes how a user might escalate simply by going to a page with higher authorization via its hyperlink.
Actors	- Thief - Employee - Script Kiddie - Penetration Tester
Triggers	- Penetration testing - Privilege escalation to cover up tracks - Employees may want to get revenge on another employee or cover up one's mistake.
Pre-conditions	- An address bar for url modification

	- The actor should have adequate knowledge on the specific url for the desired page destination or have some tools to discover the urls
Basic-Flows	A user would get access to any page of the website and may delete any text after a "/" to see if the directory has not been secured. Here's an example of an unsecured directory.  The attacker would be able to view/download the code.
Alternate Flow 1	If the directory was protected, the attacker will not be able to view the code.
Post-conditions	After looking through the code, they might be able to understand security measures, sensitive informations to bypass authentication.

7.2.7 Cross Site Request Forgery(CSRF)

Description	An attack using cross site request forgery utilises a different site to execute activities that they are unaware of. This can be in the form of fund transactions, deletion of accounts, or even changing of passwords.
Actors	- Threat actors - Penetration Tester
Triggers	- Penetration testing - Privilege escalation - Cause harm to users (deleting accounts, purchasing unwanted products) - Gain control of accounts(Changing emails, passwords)

Pre-conditions	- Knowledge on the routes of the website for certain actions - Social engineer the victim into going to the specific websites
Basic-Flows	A victim will get to understand how the website works and which routes accomplish essential tasks. For example, the website www.website.com/delete will delete the user who is currently signed in through a GET request after getting the cookie. An attacker can create their website to send the exact same GET request using the same site, schema, and port(www.website.com/delete) which will delete the users account as cookies are still present through different sites. By doing so, the user unsuspectingly deletes their account. Malicious activities such as the transference of funds, deletion of accounts, and changing of database information are some surface-level activities that a threat actor can do.
Alternate Flow 1	If the cookie is configured to be same site, it would only be present for requests sent by the same domain
Alternate Flow 2	An Anti-CSRF token can also be used. The token will be stored in the session on the server's side and will not be readable or reproducible by hackers due to the same-origin policy
Post-conditions	The attacker will achieve his finished tasks of manipulating the user into achieving their activity.

8. Non-Functional Requirements

8.1 Application Security

Misuse Preventions

As the team has identified abuse use cases and potential ways to hack the system, there has also been a plethora of methods to prevent this. Regular expressions are used to validate inputs, especially when sending data to the database. However, we also checked for any potential vulnerabilities such as malicious inputs, incorrect emails

and too simple passwords. To prevent directory traversing, the website has been routed using PHP to constraint users to access files only we would want to access.

The website will also be secure with HTTPS to encrypt and prevent any external parties from listening. Broken authentication is one of OWASP's top ten risks. As such, our sessions will only be placed in the backend via PHP to prevent or make it difficult for hackers to steal this information. Moreover, sessions will be encrypted to reduce any reading of information.

To prevent cross-site scripting, we will disallow cookies from other websites, ensuring that it is only through SSL. Since XSS can also be performed on input boxes, we will also validate input.

Obfuscation will also be utilised for code such as javascript that the client can see. Even if no sensitive information or codes are present, obfuscation will mislead the attacker as it would be hard to interpret.

IPS (Intrusion Prevention System)

The web application will only also have a web application firewall and next-generation firewall to filter and restrict which types of traffic are allowed. An ASA(Adaptive Security Appliance) by Cisco would restrict traffic, dropping and allowing various packets to enter. Additionally, the firewall will also use TCPWrapper, Windows Defender or/and IPTables(Linux) to enhance its security if the ASA were to go down. This ensures that the server will only allow ports 80 and 443.

Fail2Ban, an intrusion prevention system will work alongside our server. By monitoring traffic, it can view whether high amounts of traffic originated from the same source. The suspicious traffic will then be automatically blocked for a given period of time.

8.2 Costs

Development

In the **development** phase of our project, we did not require any money to develop our web application as we leveraged resources that can be found online for free such as Stackoverflow, Google, Youtube and LinkedIn Learning. However, we had to make a few purchases to aid in the development for our web application. Firstly, we are required to purchase SSL Certification to better secure our website by encrypting sensitive information to prevent man-in-the-middle attacks. This is an extremely vital purchase as it will prevent information of our valuable clients from being obtained.

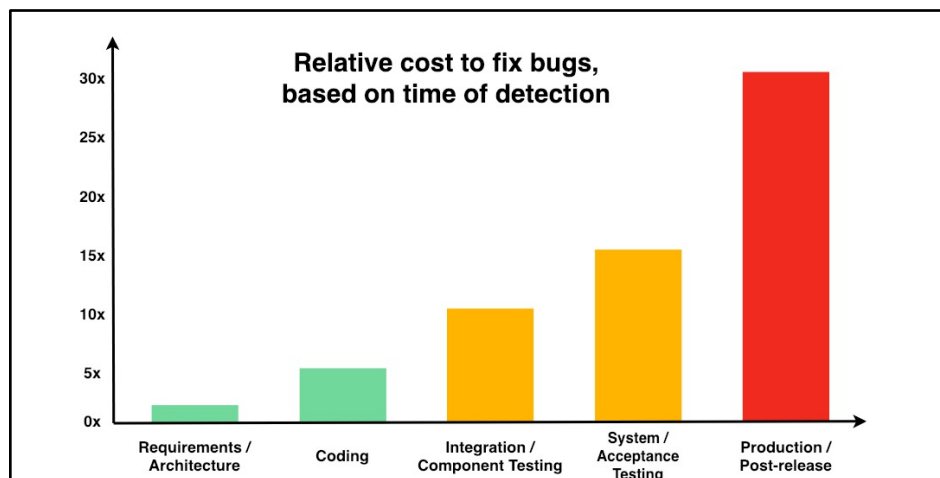
Lastly, we purchased a dedicated server to host our website on. This is because of a number of factors such as security, reliability and up-time.

Operational

In the **operational** phase of our project, we have to pay the annual fees for SSL Certification and dedicated server hosting. Moreover, there will need to be a financial backup if the server wants to scale to a larger operation (additional servers, features). Maintenance will also be imperative to the server. As **maintenance requires the largest costs**, a large amount of sum will have to be taken into account.

Cost of fixing bugs

Ultimately, bugs are unavoidable in the future of a web application.



As shown in the graph above, the relative cost of fixing bugs is increasing as each phase of development passes. Ultimately after the post-release, the cost to fix a bug would be the most costly compared to if the bug is detected in the early phases of development.

8.3 Maintainability

Maintainability is defined as the support, change, enhancement, and restructuring of our web application. Our web application might potentially need to adapt to new versions of database, languages, and APIs if they are deprecated. As the application gains more users, we also need to increase our disk space to fit the space requirements.

As mentioned previously, SSL certificates will need to be renewed when near the expiration date. Moreover, servers have to be updated and web applications such as Apache need to be patched regularly.

8.4 Scalability

Scalability is defined as our website's ability to handle increasing workload. We have designed it to minimally affect our availability and performance.

To start, our website will only be down if there is scheduled maintenance or any unforeseen circumstances such as attackers or potential bugs. In future, we will plan to have this server run on **Debian 10.10 with 4 virtual CPUs, 16GB of ram via Google Cloud Hosting**. This ensures that even a higher amount of traffic would not be able to crash or slow down the server. As such, we facilitate a high uptime and high availability.

With an increased amount of entries to our database, the server will not slow down greatly or crash, as our code is carefully designed to take up the least time and space(memory) constraint as possible. We have aimed to use the Big O notation of $O(n)$ for our space and time constraints when possible.

With the help of JWT(JSON Web Token), information to identify a user will be stored on the client's side as well. This will be encrypted and take up less space as JWT does not consume much server resources as compared to sessions.

8.5 Logging

There will be constant monitoring over the Apache web server that will automatically provide a server log on a local drive. Malicious activity will be logged according to one's IP address if detected. This provides more information and clarity if our server has gone down, or if suspicious activities have occurred. In regards to sensitive exchange of information, these logs will also be marked and be given higher priority.

Web Intrusion Detection System(IDS) & Intrusion Prevention System (IPS)

We will be implementing a Web IDS which will analyze **real-time** log files which are generated. All new log entries in the access log files are read. Analysis is performed as the new log entries are added to the log file. With the use of a Web IDS, we will be able

to detect automated exploits, automated vulnerability scanners, manual attacks and uncommon user behaviour which will log as malicious intent. Upon detecting a security policy violation, virus or configuration error, the Web IDS will ticket this information on high alert. Followingly, it will be sent to an IPS, which will kick offending users off the network and send an alert to our security personnel.

8.6 Backup

To prevent any loss of data should there be an event of a sudden crash or ransomware attacks to the website, we will implement backups. TP AMC website is highly dynamic, with data being modified to the database very frequently. As such, implementing automatic backups to our website will take place on a daily basis. Both the database as well as the codes of the website will be backed up. Should any sudden events crash the website or be caused by a technical fault, we will use the saved backup to revert the site to its last functional state.

On top of that, all of our backups will be stored in the local drive and on a cloud. By saving our website backup on multiple locations, it will add an additional layer of security. Even if a backup gets deleted or compromised, there will still be a failover.

8.7 Multi-lingual support

To better support clients from different countries and nationalities, we will be implementing multi-lingual support on our web application so that non english clients will be able to use our web application in their native language. This will be extremely beneficial to the website as we will be able to increase global brand presence, we will be able to reach more people if we localise content which in turn will increase the size of our online audience.

Furthermore, English is no longer the universal language of the internet. As of March 2020, only **25.9% of internet users** were English natives. In contrast, 3.4 billion people are from non-English speaking countries. Most internet users will skip past non-localised websites in preference to sites that offer multiple languages. TPAMC will have employees and users which speak different languages, so multilingual support would be pertinent to this.

8.8 Load Balancing

In the scenario of high traffic towards the web application, we will dedicate multiple servers to load-balance incoming traffic through round-robin. As such, servers will not go down due to high traffic. Even in the scenario that a server has gone down, other servers will be able to take over as failovers.

9. Test Plan

SWAPAMC			
No	Description of Function	Pass/Fail	Remarks
Public User			
1	Public User is able to view home page of the website		
2	Public User is able to view ecommerce page but cannot buy products		
Authenticated User			
1	Authenticated User is able to sign up		
2	Authenticated User is able to log in		
3	Authenticated User is able to verify email OTP and Google Authentication OTP		

4	Authenticated User is view list of products in TPAMC shop		
5	Authenticated User is able to add the products to cart		
6	Authenticated User is able to delete the products in cart		
7	Authenticated User is able to checkout the cart and make payment		
8	Authenticated User is able to confirm and make payment		
9	Authenticated User is able to view their past purchases		
10	Authenticated User is able to edit the account details		
11	Authenticated User is able to delete their account		
Employee			
1	Employee is able to view the earlier time slots for booking		
2	Employee is able to book time slots		

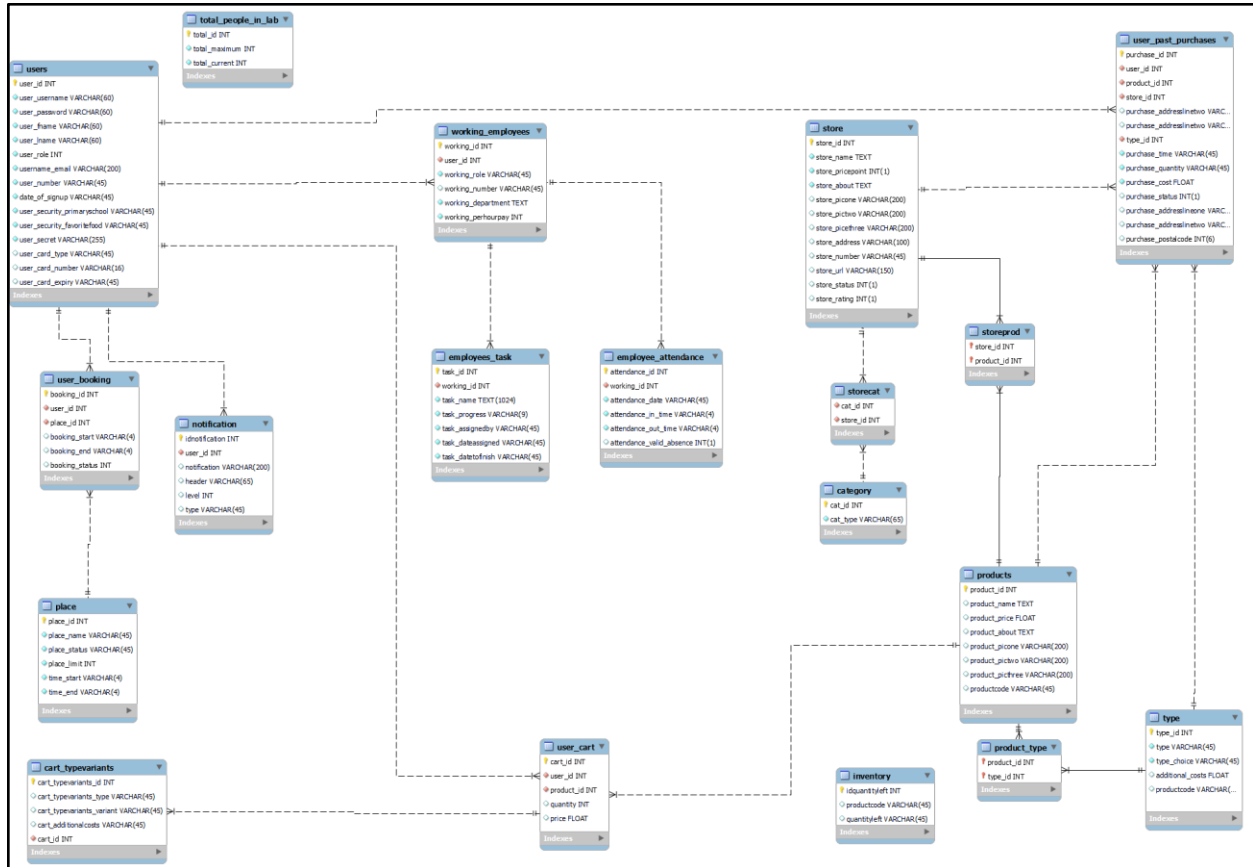
3	Employee is able to confirm and make payment		
4	Employee is able to access the Employee booking page		
5	Employee is able to view the tasks assigned by Employee Manager		
6	Employee is able to modify the status of the tasks assigned by Employee Manager		
Employee Manager (HR)			
1	Employee Manager is able to access public, employee booking and employee admin page		
2	Employee Manager is able to assign tasks to employees		
3	Employee Manager is able to view current status of the tasks		
4	Employee Manager is able to edit the tasks		
5	Employee Manager is able to delete the tasks		
6	Employee Manager is able to mark attendance of the currently working employees		

7	Employee Manager is able to CRUD employee accounts		
Store Manager (SM)			
1	Store Manager is able to access public, employee booking and store admin page		
2	Store Manager is able to purchase materials from manufacturer		
3	Store Manager is able to view materials inventory		
4	Store Manager is able to view store products		
5	Store Manager is able to edit store products		
6	Store Manager is able to add new store products		
7	Store Manager is able to delete new store products		
Booking Manager (BM)			
1	Booking Manager is able to access public ,employee booking and booking admin page		

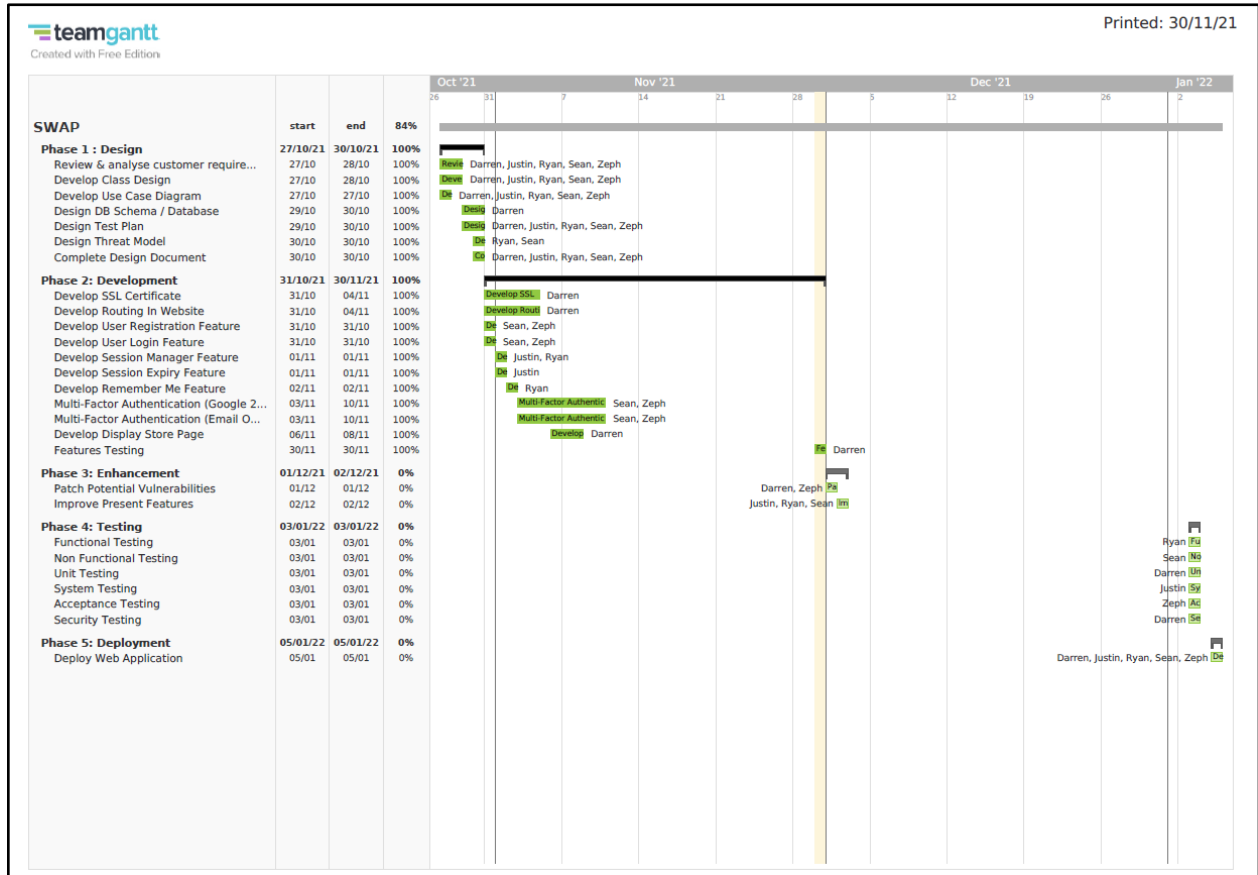
2	Booking Manager is able to view the time slots		
3	Booking Manager is able to edit the time slots		
4	Booking Manager is able to delete the time slots		
Overall Manager (OM)			
1	Overall Manager is able to do BM,SM,HR roles		
2	Overall Manager is able to view employee account		
3	Overall Manager is able to create employee account		
4	Overall Manager is able to view employee account		
5	Overall Manager is able to delete employee account		
Server Admin			
1	Server Admin is able to do everything		

10. Appendix

Appendix A

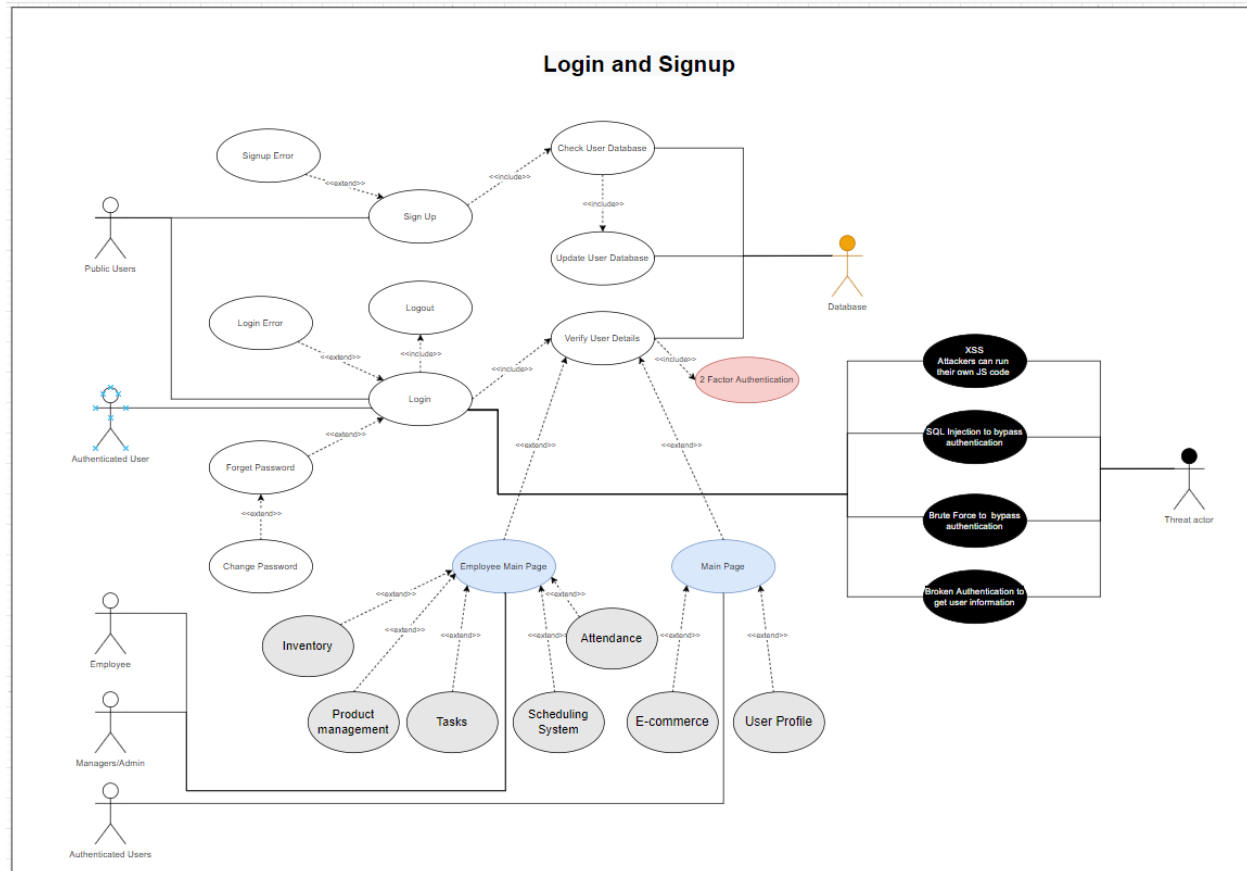


Appendix B

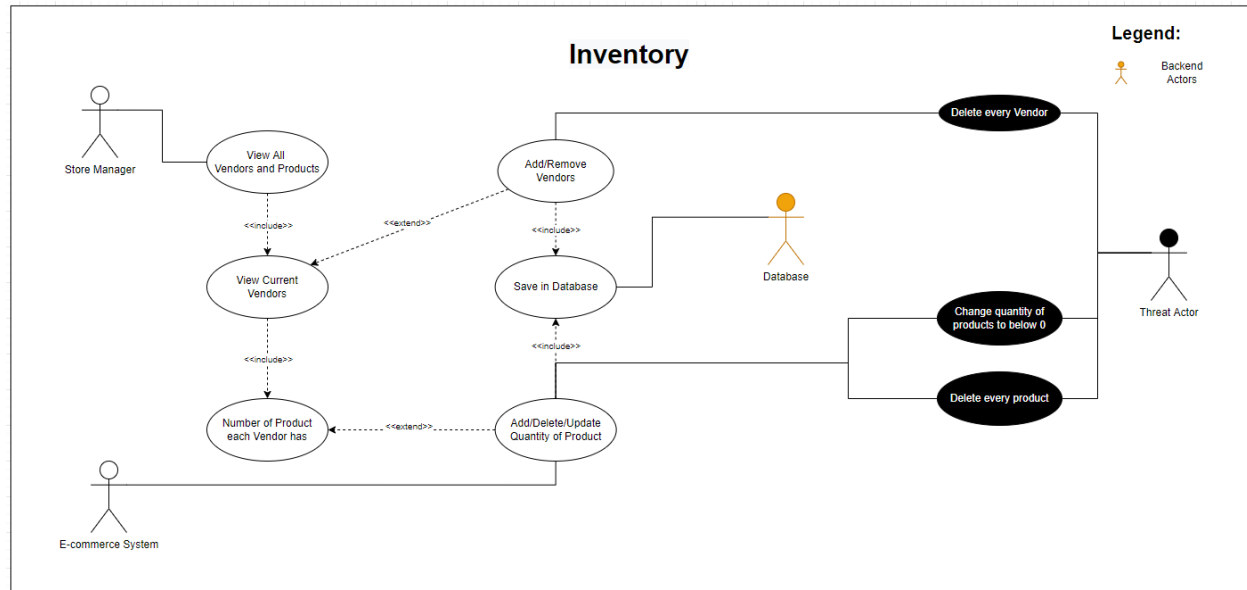


SWAP (5).pdf

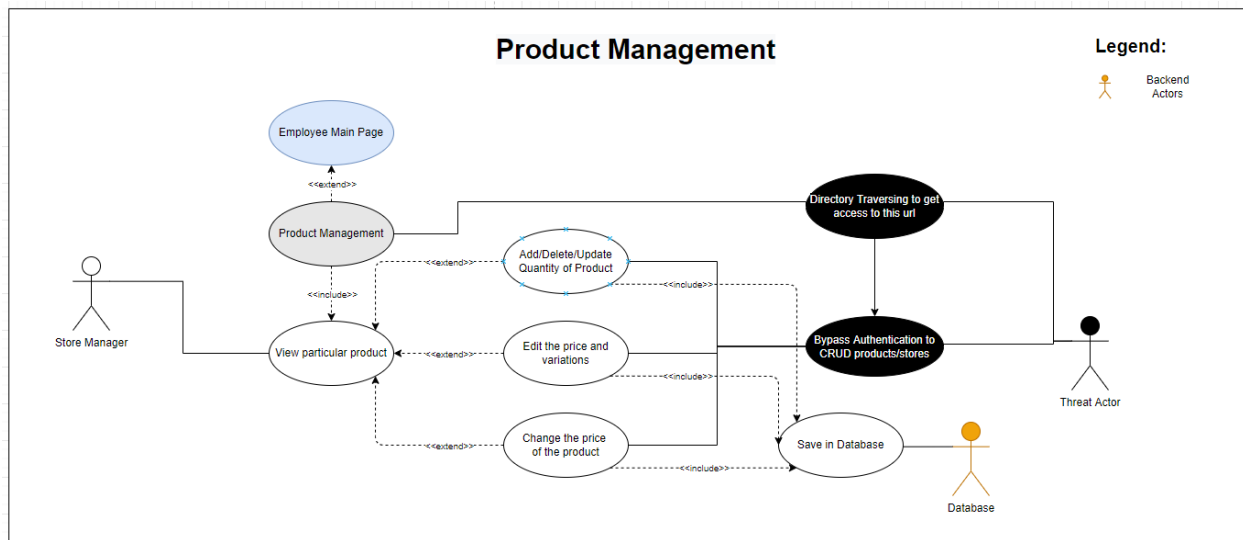
Appendix C



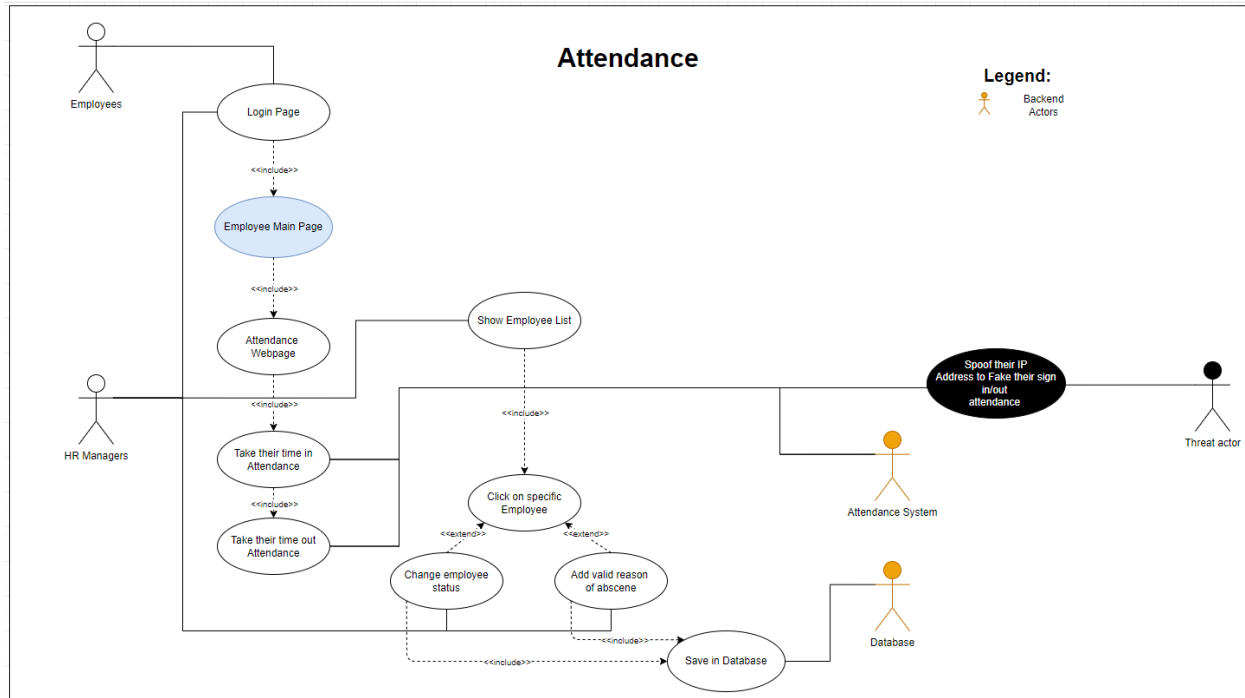
Appendix D



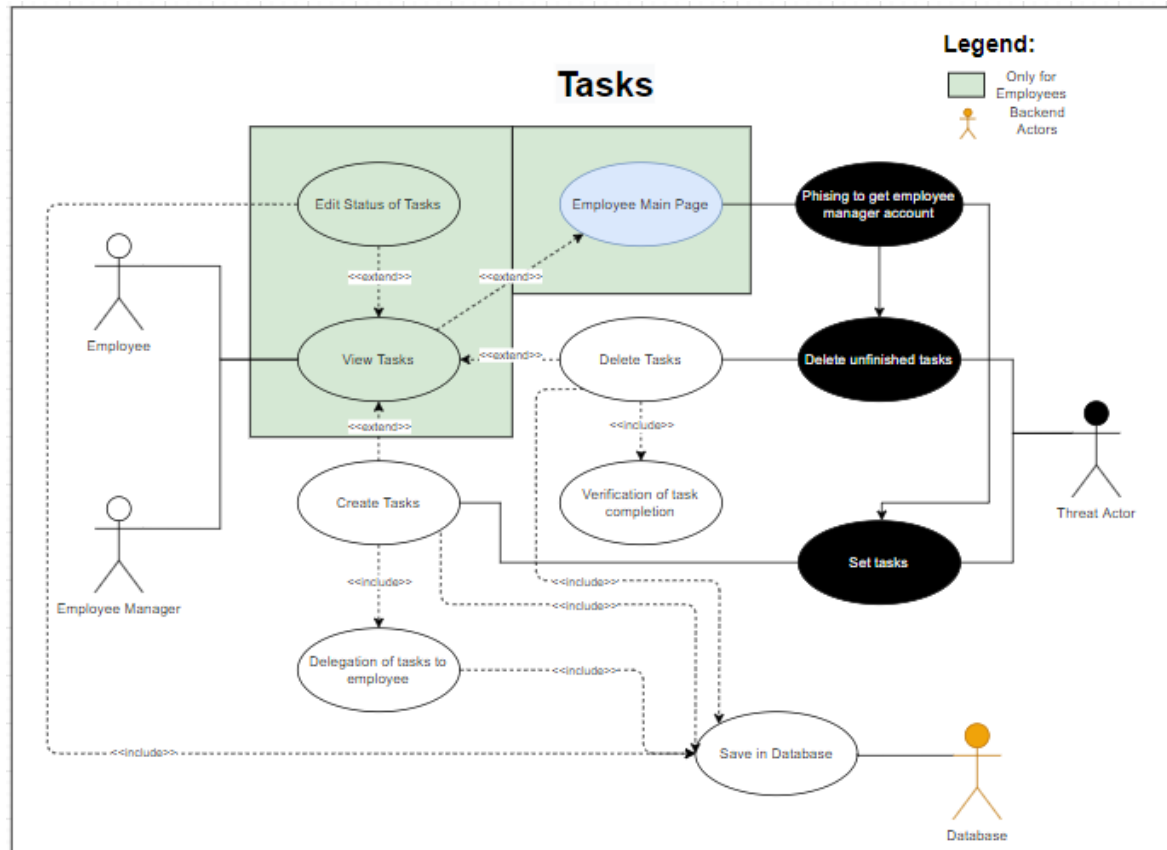
Appendix E



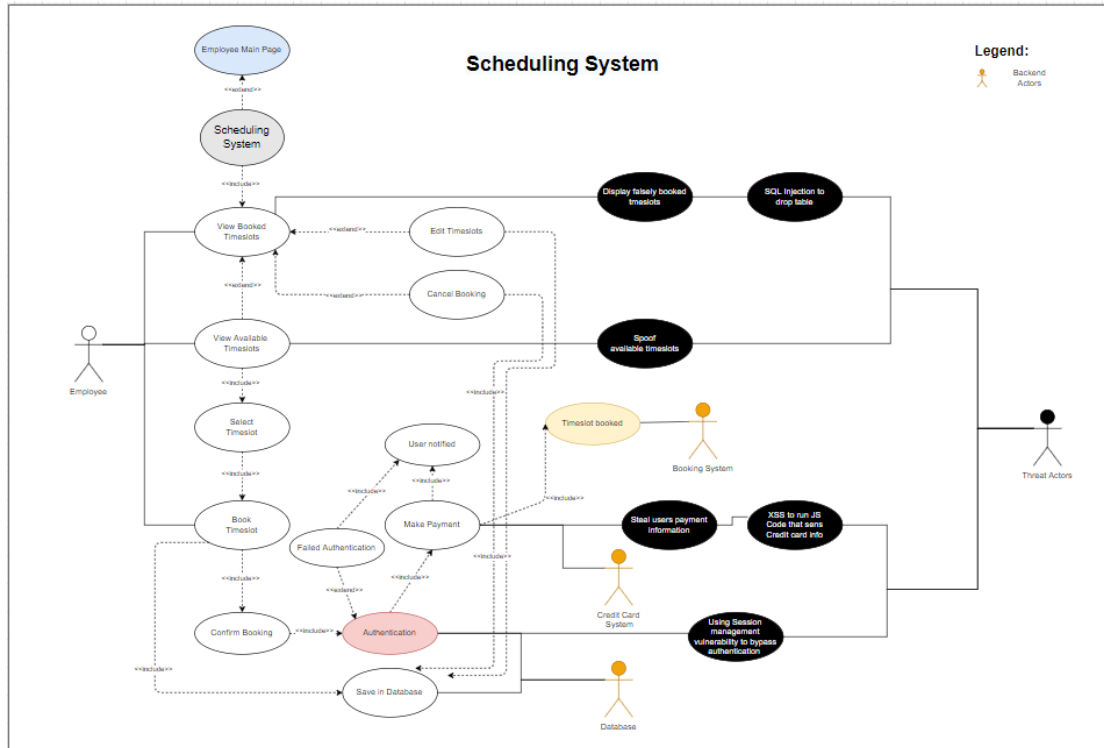
Appendix F



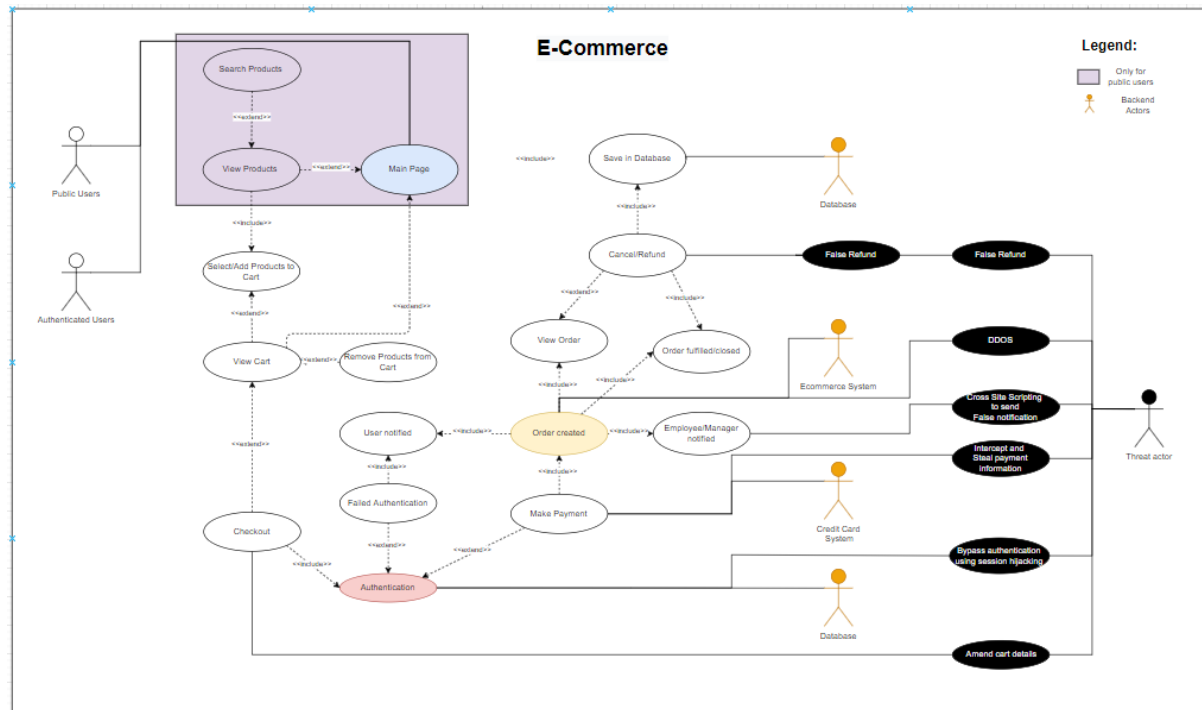
Appendix G



Appendix H



Appendix I



11. References

OWASP Top Ten. (n.d.). Retrieved from <https://owasp.org/www-project-top-ten/>

Sehlhorst, S., Says:, K. P., Says:, S. S., Says:, H. N., Says:, B. V., Says:, H. L., & Says:, J. (2007, March 10). How To Write Use Case Preconditions and Triggers: Tyner Blain. Retrieved from <https://tynerblain.com/blog/2007/03/08/use-case-preconditions-and-triggers/>

Use Case Diagram Tutorial. (n.d.). Retrieved from <https://online.visual-paradigm.com/diagrams/tutorials/use-case-diagram-tutorial/>

What is cross-site scripting (XSS) and how to prevent it?: Web Security Academy. (n.d.). Retrieved from <https://portswigger.net/web-security/cross-site-scripting>